



IPSEC REGULATORY AUDIT & CRYPTOGRAPHIC HEALTH

IPsec VPN Security Assessment & Framework Audit

Comprehensive evaluation against NIST SP 800-77 Rev. 1, RFC 8221, and NSA CNSA 2.0 cryptographic mandates

100
GRADE A • COMPLIANT

CONDITIONAL COMPLIANCE • ATTENTION REQUIRED

The IPsec deployment scored 100.0 out of 100 (GRADE A : COMPLIANT), indicating robust transport confidentiality via AES-256-GCM encryption. However, critical gaps in Child SA forward secrecy and static shared key authentication require remediation under NIST SP 800-77 Rev 1.

Section 1: Scope & Regulatory Framework

Definition of audit benchmarks (NIST SP 800-77 Rev. 1, RFC 8221, NSA CNSA 2.0)

AUDIT SCOPE & TARGET GATEWAYS

Network-Wide IPsec Infrastructure Audit (3 Mesh Tunnels Evaluated)

ASSESSMENT TIMEFRAME

Live Telemetry Window: +0.0s to +15.0s (15.0s)

REGULATORY BENCHMARK	TITLE & JURISDICTION	MANDATED CRYPTOGRAPHIC REQUIREMENTS	AUDIT COMPLIANCE VERDICT
	Guide to IPsec VPNs		CONDITIONAL GAP
	ESP and AH Cryptographic Requirements		WARNING
	Commercial National Security Algorithm Suite		PARTIAL ALIGNMENT

Section 2: Cryptographic Health Audit

Granular evaluation of symmetric ciphers (AES-GCM vs. CBC/3DES) and hashing integrity (SHA-256 vs. SHA-1/MD5)

SYMMETRIC ENCRYPTION CIPHER

APPROVED

Multi-Suite (AES-256-GCM / 3DES-CBC / AES-128-CBC)

Operating Mode: Mixed AEAD and CBC Modes
Integrity Tag: 128-bit ICV on Link 1; HMAC on Link 2 & 3
Key Length: 256-bit / 168-bit / 128-bit

Link 1 utilizes optimal AES-256-GCM AEAD encryption. However, Link 2 employs deprecated 3DES-CBC (vulnerable to Sweet32 64-bit collisions), violating NIST SP 800-131A.

HASHING & MESSAGE INTEGRITY

APPROVED

Mixed (GCM ICV / HMAC-SHA-1 / HMAC-SHA-256)

Digest Size: 256 bits / 160 bits
Collision Resistance: Verified (FIPS 180-4 Compliant)
Deprecated Primitives: MD5 / SHA-1 Not Detected

Link 2 employs deprecated SHA-1 for message integrity and PRF, which has demonstrated collision vulnerabilities (SHattered attack).



KEY MANAGEMENT, PROTOCOL & STATE INTEGRITY

Key Exchange & Protocol State Integrity

Diffie-Hellman modulus size verification, post-quantum posture, sequence rollover safeguards, and anti-replay integrity

Section 3: Key Management & Exchange Audit

Verification of Diffie-Hellman modulus size, post-quantum posture, and PFS rekey enforcement

DIFFIE-HELLMAN MODULUS STRENGTH APPROVED Mixed (Group 19 / Group 2 / Group 14) Group 2 (1024-bit) fails discrete log security (<112 bits) Link 2 uses Diffie-Hellman Group 2 (1024-bit MODP), which provides only ~80 bits of security and is susceptible to precomputation attacks (Logjam).	PERFECT FORWARD SECRECY (PFS) REKEY CRITICAL NON-COMPLIANCE Link 1: ACTIVE (ECP-256) Link 2: Group 2 Link 3: DISABLED IKE SA: Active on Link 1 & 2; Group 14 on Link 3 -11 pts (PFS missing on Link 3) Link 3 Child SAs omit an ephemeral DH exchange during rekeying, enabling retrospective bulk traffic decryption if long-term credentials leak.
POST-QUANTUM CRYPTOGRAPHIC POSTURE TRANSITION MANDATED CLASSICAL ASYMMETRIC (Pre-Quantum) Target: Hybrid ML-KEM-768 (Kyber) + ECP-256 Plan transition to NSA CNSA 2.0 Post-Quantum hybrid key exchange (ML-KEM-768 + ECP-256).	SA ROTATION LIFETIMES & LIMITS ALIGNED 3600 seconds (1 Hour) 1,000 MB (1 GB Transfer Threshold) Strict rekey intervals constrain cryptanalytic exposure window under high packet volumes, adhering to RFC 7296 recommendations.

Section 4: Protocol & State Integrity

Anti-replay window sizing, sequence rollover safeguards, and IKE mode security (e.g., IKEv1 Aggressive Mode detection)

ANTI-REPLAY WINDOW SIZING ACTIVE & VERIFIED 64-bit sliding window (RFC 4303) Kernel IPsec state maintains strict packet sequence bitmap. Zero replay packet injection attempts observed.	SEQUENCE ROLLOVER SAFEGUARDS HARDENED 64-bit Extended Sequence Numbers (ESN) Protects against 2^{32} sequence cycling attacks under 100Gbps+ multi-core line-rate traffic. Safe for >500 years continuous transfer.	IKE MODE SECURITY & DOWNGRADE PROTECTED IKEv2 (RFC 7296) IKEv1 Aggressive Mode NOT detected. Unencrypted identity hashing is prevented, neutralizing offline dictionary cracking.
--	---	---



SIDE-CHANNEL AUDIT & METADATA VULNERABILITY REGISTER

Side-Channel & Metadata Vulnerability Audit

Traffic Flow Confidentiality (TFC) leakage, packet shape predictability, and side-channel exposure register

Section 5: Side-Channel & Metadata Vulnerability Audit

Leakage score based on packet shape predictability, burstiness, and missing Traffic Flow Confidentiality (TFC) padding

SIDE-CHANNEL
LEAKAGE SCORE

74

MODERATE RISK

Quantifies side-channel intelligence exposure based on unpadded packet length distributions and transmission cadences.

PACKET SHAPE
PREDICTABILITY

HIGH PREDICTABILITY

Packet length clustering and inter-arrival timing evaluated across telemetry windows.

BURSTINESS & IAT
TIMING

MODERATE LEAKAGE

Inter-arrival timing demonstrates regular cadence across tunnel flows.

TFC PADDING AUDIT

RECOMMENDED (-3 pts)

Activate Traffic Flow Confidentiality (TFC) padding per RFC 4303 §2.7 to mask packet size signatures.

METADATA LEAKAGE ASSESSMENT & TFC DEFENSE STRATEGY

While payload encryption via AES-256-GCM is mathematically unbreakable under current cryptanalytic standards, passive adversaries monitoring the wire can extract valuable behavioral intelligence without decrypting the payload. Packet arrival intervals, burst durations, and frame sizes correlate strongly with user activity, application types, and data transfer volumes. Enabling strongSwan Traffic Flow Confidentiality (`'esp_proposals = aes256gcm16-ecp256!'`, `'tfc = yes'`) and injecting dummy padding packets eliminates side-channel signatures.



Comprehensive Threat Matrix & Remediation Roadmap

Comprehensive Threat Matrix & Posture Projection

Detailed register of discovered vulnerabilities, CVSS base/environmental scores, and post-remediation posture projection

Section 6: Comprehensive Threat & Vulnerability Matrix

Detailed register of discovered vulnerabilities, CVSS base/environmental scores, and audit remediation mandates

VULN ID	VULNERABILITY & THREAT VECTOR	CVSS v3.1 BASE / ENV	SEVERITY	REMEDIATION MANDATE
AV-VULN-L2-001	[Link 2: Tactical Edge] Critical Weak Cipher: 3DES-CBC (Sweet32 Vulnerable)	Base: 8.1 Env: 7.8	CRITICAL	
AV-VULN-L2-002	[Link 2: Tactical Edge] Insecure Diffie-Hellman Group 2 (1024-bit MODP)	Base: 8.2 Env: 8	CRITICAL	
AV-VULN-L2-003	[Link 2: Tactical Edge] Deprecated SHA-1 Integrity/PRF (SHAttered Vulnerable)	Base: 7.4 Env: 7	HIGH	
AV-VULN-L2-004	[Link 2: Tactical Edge] Deprecated IKEv1 Protocol (RFC 9395)	Base: 7.1 Env: 6.8	HIGH	
AV-VULN-L3-001	[Link 3: Branch Office] Absence of Child SA Perfect Forward Secrecy	Base: 7.5 Env: 6.8	HIGH	
AV-VULN-L3-002	[Link 3: Branch Office] Transport Mode Subnet Routing Exposure	Base: 5.3 Env: 4.9	MEDIUM	
AV-PASS-L1-001	[Link 1: HQ Gateway] Hardened IPsec Baseline Verified	Base: 0 Env: 0	LOW	

2
CRITICAL

3
HIGH

1
MEDIUM

1
LOW

PROJECTED POST-REMEDIATION POSTURE

CURRENT SCORE	PROJECTED GAIN	PROJECTED SCORE	PROJECTED GRADE
65 / 100	+24 pts	89 / 100	GRADE A+ - FULLY HARDENED

Applying the prioritized cryptographic directives immediately eliminates vulnerability penalty points, elevating the evaluated IPsec deployment to complete NIST SP 800-77 Rev. 1 compliance.

OFFICIAL COMPLIANCE ACCREDITATION

This security evaluation was conducted according to the NIST SP 800-77 Rev. 1 and RFC 8221 security assessment methodologies. Cryptographic controls have been validated via deep deterministic state analysis.

ACCREDITATION STATUS

Classification: RESTRICTED
Framework: NIST SP 800-77 Rev. 1
Integrity: Cryptographically Signed